

Chapitre 1 – Monitoring réseau

1. Définitions essentielles

- Monitoring : surveillance en temps réel de l'état et des performances d'un système, incluant l'état actuel et l'historique.
- Métrologie : ensemble des méthodes et techniques pour effectuer des mesures (charge CPU, trafic réseau) et tracer des graphiques d'évolution.
- Supervision : analyse des données collectées afin de comprendre les tendances, anticiper les problèmes et optimiser les performances.

2. Pourquoi superviser ?

- Avoir une connaissance du fonctionnement du réseau.
- Identifier les goulots d'étranglement et les utilisateurs consommant le plus de bande passante.
- Créer une ligne de base réseau (Network Baseline) pour détecter les anomalies et suivre la croissance du trafic.
- Mettre en place des alertes rapides en cas de problème (serveur inaccessible, interface down).

3. Quoi superviser ?

- Superviser tout ce qui peut être utile pour anticiper l'évolution et être averti rapidement des problèmes.
- Mais "tout mais pas trop" :
 - Trop d'indicateurs consomment des ressources (CPU, bande passante).
 - Pollution de la visibilité des incidents importants.
 - Beaucoup de travail pour peu de résultats.
- Une analyse est nécessaire selon les besoins, les ressources critiques et les ressources disponibles.

Exemples d'éléments à superviser

- | | |
|--|---------------------------------|
| • % de bande passante utilisée | • Ports en erreur |
| • % de paquets en erreur ou de diffusion | • Mémoire et CPU utilisés |
| • Température | • Authentifications incorrectes |
| | • État des services |

4. Comment superviser ?

Méthode active (Polling / Sondage)

- La station de gestion envoie une requête et le périphérique répond.
- Induit un délai entre l'événement et sa journalisation.
- Consomme des ressources même sans information utile.

Méthode passive (Trap / Déroutement)

- L'équipement prend l'initiative de signaler un événement.
- Basée sur des états ou des seuils définis par l'administrateur.

5. Vérification de services

- Pinger un périphérique ne garantit pas le fonctionnement d'un service.
- Vérifier le processus ne garantit pas la fourniture du contenu.
- Le système de monitoring doit pouvoir tester l'accès au contenu (ex : lire une page web).

6. Gestion des alarmes

- Déterminer quand générer une alarme.
- Limiter les alertes pour éviter la surcharge d'informations.
- Clarifier le niveau d'importance des alarmes.
- Alerter les bonnes personnes via les canaux adaptés (console, mail, SMS).
- Utiliser un temporisateur pour éviter les alertes répétitives.
- Filtrer les alertes pour éviter les cascades d'alarmes.

7. Gestion des actions de correction

- Possibilité d'automatiser des actions (ex : redémarrer un service).
- Attention aux effets néfastes d'une automatisation mal pensée (maintenance).

8. Conservation des données

- Déterminer quelles données conserver (évolution du réseau).
- Définir le niveau de détail :
 - À long terme, les tendances générales sont les plus intéressantes.

9. Documentation

- Lister et classer les éléments à superviser par criticité.
- Rédiger une base de connaissances (erreurs, correctifs).
- Conserver l'historique des alertes pour remonter à la source des incidents.

10. Protocoles et outils de supervision

- Protocoles : Syslog, SNMP, NetFlow / IPFIX
- Outils : Centreon, PRTG Network Monitor ,SolarWinds Network Performance Monitor, Nagios , Zabbix

11. Syslog

- Messages système : les périphériques envoient des messages lors d'événements (ex : changement d'état d'interface).
- Protocole Syslog : protocole de journalisation d'événements utilisant le port UDP 514.
- Disponible sur de nombreux périphériques réseau.

Destinations des messages

- Mémoire tampon
- Console
- Terminal (vty)
- Serveur Syslog externe

Niveaux de gravité

- Niveau de gravité de 0 (Emergencies) à 7 (Debugging).
- Plus le numéro est petit, plus l'alarme est critique.

Facility Syslog

- Identifie l'appareil, le protocole ou le module qui logue le message.

- Facilite le classement des messages.

Format des messages

- seq no: timestamp: %facility-severity-MNEMONIC: description

Horodatage

- Nécessite une horloge correctement configurée (manuelle ou NTP).
- Activation de l'horodatage des messages.

Journalisation vers un serveur Syslog externe

- Permet :
 - Un enregistrement centralisé
 - Un affichage ergonomique
 - Des recherches facilitées
 - La suppression rapide des messages non importants

12. SNMP (Simple Network Management Protocol)

- Définition : protocole permettant de gérer et superviser les équipements réseau.
- Utilise le port UDP 162.
- Permet de :
 - Gérer les équipements
 - Superviser (récolte de données)
 - Diagnostiquer les problèmes

Composants SNMP

- Gestionnaire SNMP (NMS) : serveur de gestion.
- Agents SNMP : présents sur les équipements.
- MIB (Management Information Base) :
 - Base de données d'informations.
 - Structure arborescente.
 - Chaque information est identifiée par un OID.

Versions SNMP

- SNMPv1 : community en texte clair.
- SNMPv2c :
 - Compteurs 64 bits
 - getbulk
 - Community en clair (risque faible en lecture seule).
- SNMPv3 :
 - Authentification
 - Intégrité
 - Confidentialité
 - Utilisable sur des réseaux étendus.

Bonnes pratiques

- Utiliser SNMPv3 si possible.
- Désactiver la communauté « public ».
- Utiliser des communautés en lecture seule.
- Limiter l'accès via des ACL.

13. NetFlow / IPFIX

- NetFlow : technologie Cisco de collecte et de surveillance du trafic IP.
- IPFIX : version standardisée basée sur NetFlow.
- Permet de :
 - Comprendre l'utilisation de la bande passante par les applications.
 - Déterminer qui génère le plus de trafic.
 - Identifier les sites web visités et le contenu téléchargé.
 - Identifier et dépanner les goulots d'étranglement.
 - Vérifier les performances des règles QoS.

Comparaison

- NetFlow : statistiques de trafic précises.
- SNMP : informations sur interfaces, CPU, erreurs.
- Analyseur réseau : capture toutes les données.
- NetFlow cible uniquement les données pertinentes.

Principe de fonctionnement

- Basé sur des flux TCP/IP unidirectionnels.
- Les flux sont distingués par :

○ IP source	○ Protocole L3
○ IP destination	○ TOS
○ Port source	○ Interface d'entrée
○ Port destination	

Table des flux

- Les flux sont stockés dans une table cache.
- Le flux se termine :
 - Après inactivité
 - Après une durée maximale
 - À la fin de la session (RST, FIN)
- Une fois terminé, le flux est exporté vers un collecteur NetFlow.

Flexible NetFlow et IPFIX

- Permettent de définir :
 - Les champs utilisés pour distinguer les flux
 - Les données exportées
- Réduction des données inutiles.

Chapitre 2 – AAA

1. Introduction à AAA

- AAA : ensemble de concepts et mécanismes permettant de sécuriser l'accès aux réseaux et aux systèmes.
- AAA permet de :
 - contrôler qui peut se connecter (authentification),
 - définir ce qu'ils peuvent faire (autorisation),
 - garder une trace de leurs actions (comptabilisation / audit).

2. Types d'authentification

Authentification locale

- Par mot de passe uniquement :
 - Protection simple des accès console et terminaux.
 - Ne permet pas d'identifier l'utilisateur.
- Par couple username / password :
 - Nécessite des comptes utilisateurs locaux.
 - Permet d'identifier l'utilisateur.
- Base de données locale :
 - Chaque périphérique est configuré individuellement.
 - Lourde pour les grands réseaux.
 - Ne propose pas de méthodes de secours.
- Authentification AAA locale :
 - Similaire à la base locale.
 - Permet de définir des méthodes d'authentification de secours.

Authentification centralisée

- Les couples username/password sont stockés sur un serveur distant.
- Protocoles utilisés : RADIUS et TACACS+.
- Plusieurs serveurs peuvent être configurés pour la redondance.
- Exemples : Cisco ISE, Active Directory, LDAP, FreeRADIUS

3. Fonctions AAA

1. Authentication (Authentification)

- Vérifie l'identité de l'utilisateur.
- Méthodes :
 - Ce que l'utilisateur sait (mot de passe)
 - Ce qu'il a (badge, token)
 - Ce qu'il est (empreinte digitale, scan rétinien)
- Authentification forte : utilisation d'au moins deux facteurs.
- Le périphérique envoie une requête au serveur AAA qui valide l'accès.

2. Authorization (Autorisation)

- Détermine les accès et droits de l'utilisateur une fois authentifié.
- Une requête est envoyée au serveur AAA pour chaque action.
- Peut générer un grand nombre de requêtes sur de grands parcs de machines.

3. Accounting / Auditing (Comptabilisation / Audit)

- Enregistre des données sur l'utilisation des systèmes.
- Objectifs :
 - Facturation
 - Audit
 - Dépannage
 - Détection d'actions suspectes
 - Traçabilité légale
- Données enregistrées :
 - Commandes exécutées
 - Temps de connexion
 - Volume de données
 - Connexions Telnet / SSH
 - Événements système

4. Protocoles de communication AAA

TACACS+

- Séparation de l'authentification et de l'autorisation.
- L'intégralité du paquet est chiffrée.
- Utilise TCP.
- CHAP bidirectionnel.
- Protocole propriétaire Cisco.
- Incompatible avec les anciennes versions de TACACS.

RADIUS

- Authentification et autorisation associées.
- Seul le mot de passe est chiffré.
- Utilise UDP :
 - 1812 : authentification
 - 1813 : comptabilisation
- CHAP unidirectionnel.
- Possibilités de comptabilisation étendues.
- Protocole standard ouvert.

5. Configuration AAA sur Cisco IOS

- Activation : aaa new-model
- Conseil : configurer un utilisateur et un mot de passe avant l'activation.
- Possibilité de définir :
 - Authentification
 - Autorisation
 - Comptabilisation
- Par défaut, l'autorisation n'est pas activée.
- Une fois activée, tous les accès sont refusés par défaut.

6. Norme 802.1X

- Port-based Network Access Control.
- Refuse l'accès au réseau tant que l'utilisateur n'est pas authentifié.

Composants

- Supplicant : logiciel client.
- Authenticator : contrôle l'accès physique (souvent un switch).
- Authentication Server : serveur d'authentification (souvent RADIUS).

États d'un port 802.1X

- Auto : port non autorisé jusqu'à authentification réussie.
- Force-authorized : tout le trafic est autorisé.
- Force-unauthorized : tout le trafic est refusé.

7. Protocoles d'authentification

- PAP :
 - Mot de passe en texte clair.
 - Peu fiable.
- CHAP :
 - Authentification en trois étapes.
 - Mot de passe non transmis directement.
- MS-CHAPv2 :
 - Authentification mutuelle.
- EAP/TLS :
 - Authentification via certificats.
- EAP/PEAP :
 - Tunnel chiffré.
 - Authentification serveur par certificat.
- EAP/TTLS :
 - Similaire à PEAP.
 - Méthodes d'authentification plus flexibles.

8. FreeRADIUS

- Serveur RADIUS Open Source.
- Supporte LDAP, AD et SQL.
- Supporte EAP/TLS et PEAP.
- Multi-plateforme.
- Utilisé par les FAI, les entreprises et Eduroam.
- Outils de test et debug intégrés.

Chapitre 3 – Port Mirroring

1. Introduction au Port Mirroring

- Principe : le port mirroring est une fonction de surveillance qui permet à un commutateur de copier le trafic Ethernet entrant par un ou plusieurs ports (ports source) et de l'envoyer vers un port de destination.
- Objectif :
 - Le port de destination est connecté à un dispositif d'analyse (analyseur de paquets, IDS).
 - Permet d'analyser le trafic sans perturber le fonctionnement normal du réseau.
 - La trame d'origine est transmise normalement.
- Risque :
 - Peut entraîner une congestion sur le port de destination si le volume de trafic copié est trop important.

2. Terminologie

- Synonymes :
 - SPAN
 - miroir de port
 - port d'écoute
 - port monitoring
- SPAN (Switched Port ANalyzer) :
 - Terme Cisco pour le port mirroring local.
- VSPAN (VLAN-based SPAN) :
 - Surveille tous les ports appartenant à un VLAN particulier.
- RSPAN (Remote SPAN) :
 - Utilisé lorsque les ports source et destination ne sont pas sur le même commutateur.
 - Le trafic est transporté via un VLAN RSPAN dédié.

3. Concepts clés du Port Mirroring

- Ingress traffic : trafic entrant sur un port.
- Egress traffic : trafic sortant d'un port.
- Source (SPAN) ports : ports dont le trafic est surveillé et copié.
- Destination port (Monitor port) : port qui reçoit la copie du trafic.

4. Session SPAN

- Définition :
 - Association entre un ou plusieurs ports source (ou VLAN source) et un ou plusieurs ports de destination.
- Trafic surveillé :
 - Trafic reçu (Rx)
 - Trafic transmis (Tx)
 - Trafic bidirectionnel
- Identification :
 - Une session SPAN locale est identifiée par un numéro de session.

5. Caractéristiques d'un Port Source SPAN

Flexibilité

- Peut être n'importe quel type de port.
- Peut être surveillé dans plusieurs sessions SPAN.
- Peut surveiller le trafic en entrée, en sortie ou les deux.
- Peut se trouver dans le même VLAN ou dans des VLAN différents.
- Peut être un port de couche 2 ou de couche 3.

Restrictions

- Un port source ne peut pas être un port de destination.
- Les sources d'une session SPAN peuvent être des ports ou des VLAN, mais pas les deux à la fois.

Nombre

- Un commutateur peut prendre en charge un nombre quelconque de ports source et de VLAN source.

6. Caractéristiques d'un Port de Destination SPAN

- Rôle :
 - Reçoit une copie du trafic des ports source et/ou VLAN source.
 - Appelé port de surveillance.
- Exclusivité :
 - Chaque session SPAN locale ou Remote SPAN doit avoir un port de destination.
 - Un port de destination ne peut participer qu'à une seule session SPAN.
 - Un port de destination ne peut pas être un port source.

Comportement spécial

- N'est plus un port de commutation normal.
- Seul le trafic surveillé transite par ce port.
- État up/down par conception.
- Ne participe pas :
 - au protocole STP
 - aux protocoles de couche 2 (VTP, CDP, DTP, PAgP)

7. Configuration du SPAN Local

- Associer un port source :
 - `monitor session <number> source interface | vlan [both | rx | tx]`
- Associer un port de destination :
 - `monitor session <number> destination interface | vlan`
- Supprimer les configurations :
 - `no monitor session`
- Vérification :
 - `show monitor`

8. Remote Port Mirroring (RSPAN)

- Utilité :
 - Lorsque l'analyseur de paquets ou la sonde IPS se trouve sur un commutateur différent.
- Fonctionnement :
 - Utilise deux sessions :
 - une session source
 - une session de destination
 - Le trafic est transporté sur des liaisons trunk dans un VLAN RSPAN dédié.
 - Le VLAN RSPAN doit être configuré sur tous les commutateurs participants.
- Volume de trafic :
 - Chaque paquet est transmis deux fois.
 - Peut générer de grandes quantités de trafic réseau.

9. Configuration du Remote SPAN (RSPAN)

1. Créer le VLAN RSPAN sur tous les commutateurs.
2. Créer la session RSPAN source sur le commutateur source.
3. Créer la session RSPAN destination sur le commutateur de destination.

Chapitre 4 – VRF

1. Introduction au Virtual Routing and Forwarding (VRF)

- Objectif principal : les VRF permettent l'isolation du trafic réseau.
- Elles sont utilisées lorsque des organisations doivent :
 - séparer différentes classes de trafic,
 - isoler des groupes spécifiques d'utilisateurs.

Exemples d'utilisation

- Séparer le trafic :
 - invité
 - sous-traitants
 - vidéosurveillance IP
- Les fournisseurs de services interconnectent de nombreux sites et services via un même réseau fédérateur tout en souhaitant les isoler les uns des autres.

2. Isolation du trafic : Physique vs Virtuelle

Isolation physique

- Utilisation d'une infrastructure dédiée pour chaque entité.
- Génère des coûts d'infrastructure importants.

Isolation virtuelle (avec VRF)

- Création de plusieurs routeurs logiques dans un routeur physique.
- Chaque VRF possède :
 - sa propre table de routage,
 - une isolation complète des trafics utilisateurs.

- Les VRF peuvent être utilisées :
 - avec des VPN,
 - avec des protocoles de routage dynamiques.

3. Fonctionnement des VRF

Tables de routage indépendantes

- La table de routage globale (GRF) est utilisée par défaut.
- La GRF contient les interfaces IP ne faisant pas partie d'un réseau virtuel.
- Chaque VRF dispose d'une table de routage :
 - distincte de la GRF,
 - distincte des autres VRF.

Affectation des interfaces

- Une interface (physique ou sous-interface) peut appartenir à une seule VRF.

Routage isolé

- Les paquets sont routés uniquement selon les routes de la VRF concernée.
- Les paquets arrivant sur une interface sont transmis uniquement aux interfaces du même réseau virtuel.

Adresses IP chevauchantes

- Possibilité d'utiliser des adresses IP identiques ou qui se chevauchent.
- Chaque VRF maintient son propre espace d'adressage.

Isolation étendue

- L'isolation peut s'étendre :
 - jusqu'aux routeurs CE,
 - jusqu'aux VLAN.

4. VRF-Lite

- Les VRF ont été introduits avec MPLS.
- La technologie a évolué pour devenir indépendante de MPLS.
- VRF-Lite : utilisation des VRF sans MPLS.

5. Configuration de VRF-Lite (logique essentielle)

1. Création des VRF

- Définition du nom et description de la VRF.

2. Activation d'IPv4 dans la VRF

- Étape cruciale :
 - Si une interface est assignée à une VRF avant l'activation IPv4, l'adresse IP est désactivée.

3. Assignment des interfaces aux VRF

- Une interface est associée à une VRF.
- L'adresse IP de l'interface est supprimée lors de l'assignation.
- Elle doit être reconfigurée après.

4. Création de routes statiques pour les VRF

- Les routes sont créées dans la table de routage de la VRF.

5. Routes entre VRF et/ou avec la GRF

- Utilisation du mot-clé global.
- Le next-hop est joignable via la table de routage globale.
- Attention :
 - Peut compromettre l'isolation si mal configuré.

6. Vérification de la configuration VRF

Afficher les VRF

- Affiche :
 - le nom de la VRF,
 - le Route Distinguisher (RD),
 - les interfaces associées.

Route Distinguisher (RD)

- Identifiant unique des routes d'une VRF.
- Garantit l'unicité des routes en cas de chevauchement d'adresses IP.

Tables de routage

- Table de routage d'une VRF spécifique.
- Table de routage globale.

Chapitre 5 – QoS

1. Introduction à la Qualité de Service (QoS)

Problèmes potentiels sur le réseau

- Délai (Latence) :
 - Temps nécessaire à un paquet pour aller de la source à la destination.
 - Peut être excessif en cas d'encombrement.
- Gigue :
 - Variation du délai des paquets reçus.
 - Les applications temps réel y sont sensibles.
- Pertes de paquets :
 - Dues à des interférences ou à des files d'attente saturées.
 - Très souvent la cause des problèmes de qualité en VoIP.

Besoin de QoS

- Réseaux convergents :
 - Voix, Vidéo et Données partagent la même infrastructure.
- Attentes des utilisateurs :
 - Exigences élevées en termes de qualité des services fournis.

2. Encombrement du réseau

- Se produit lorsque le volume de trafic dépasse la capacité de transport.
- Les paquets sont mis en file d'attente, entraînant des délais.
- Si les files d'attente sont pleines, des paquets peuvent être abandonnés.
- Tampon des délais de diffusion :
 - Mécanisme côté récepteur pour compenser la gigue.
 - Des pertes peuvent survenir si la gigue est trop importante.

3. Caractéristiques du trafic et sensibilité à la QoS

Trafic Voix

- Prévisible et homogène.
- Faible consommation de bande passante (min. 30 Kbits/s).
- Très sensible aux délais :
 - Latence < 150 ms
 - Gigue < 30 ms
- Très sensible aux pertes de paquets :
 - Pertes < 1 %
 - Impossible de retransmettre
- Nécessite une priorité élevée.

Trafic Vidéo

- Imprévisible : nombre et taille des paquets variables.
- Bande passante minimale : 384 Kbits/s.
- Sensible aux délais :
 - Latence < 400 ms
 - Gigue < 50 ms
- Très sensible aux pertes de paquets :
 - Pertes < 1 %
- Nécessite une priorité élevée.

Trafic de Données

- Variable : fluide ou en salve, interactif ou non.
- Moins sensible aux abandons et délais.
- Les applications fonctionnent malgré les pertes (retransmissions TCP).
- Nécessite une certaine qualité d'expérience (QoE).

4. Mise en file d'attente (Queuing)

- Objectif :
 - Gérer les encombrements en stockant, hiérarchisant et réorganisant les paquets.
- Les mécanismes QoS sont actifs uniquement en cas d'encombrement.

Algorithmes de mise en file d'attente

FIFO (First in first out)

- Méthode par défaut.
- Tous les paquets sont traités de la même manière.
- Aucune priorisation.

WFQ (Weighted Fair Queuing)

- Fournit un traitement équitable pour tous les types de trafic.
- Classe le trafic en flux.
- Privilégie le trafic interactif.
- Limites :
 - Coûteux en CPU
 - Incompatible avec la tunnellation et le chiffrement

CBWFQ (Class-Based Weighted Fair Queuing)

- Classes de trafic définies par l'utilisateur.
- Chaque classe reçoit une bande passante garantie.
- Jusqu'à 256 files d'attente.

LLQ (Low Latency Queuing)

- Garantit de bas délais pour les trafics Voix et Vidéo.
- File d'attente à priorité stricte.
- Réduction du délai et de la gigue.
- Risque de pertes si le débit dépasse la bande passante garantie.

Architecture CBWFQ + LLQ

- Combine les avantages des deux mécanismes.

5. Modèles d'implémentation QoS

Best-effort

- Aucun mécanisme QoS actif.
- Aucune garantie de remise des paquets.

Services intégrés (IntServ)

- QoS très élevée.
- Utilise RSVP.
- Garantie de bout en bout.
- Inadapté aux grands réseaux.

Services différenciés (DiffServ)

- QoS flexible et évolutive.
- Classes de trafic avec niveaux de QoS spécifiques.
- Fonctionnement saut par saut.
- Pas de garantie stricte de bout en bout.

6. Traitement des paquets

Prévention de la congestion

- TCP s'adapte à l'encombrement.
- Les applications non-TCP sont plus sensibles aux pertes.
- Solutions :
 - Augmenter la capacité
 - Utiliser WFQ, CBWFQ, LLQ
 - Supprimer les paquets non prioritaires (RED, WRED)

WRED

- Surveille la profondeur moyenne d'une file d'attente.
- Supprime sélectivement les paquets non prioritaires.
- Ne fonctionne pas pour le trafic UDP.

7. Séquence de traitement des paquets avec QoS

1. Classification et marquage
2. Prévention d'encombrement
3. Gestion de l'encombrement

8. Classification et marquage

Classification

- Couche 2 : CoS (802.1p / 802.1Q)
- Couche 3 : ACL, class-map
- Couches 4 à 7 : NBAR

Marquage

- Ajout d'une valeur dans l'en-tête du paquet.
- Réalisé le plus près possible de la source.
- Frontière de confiance (Trust Boundary).

9. Marquage DSCP et PHB

- Champ DSCP : 6 bits (64 possibilités).
- ECN : 2 bits.
- PHB :
 - CS
 - DF
 - AF
 - EF
 - Scavenger Class (CS1)

10. Limitation et régulation du trafic

Traffic Shaping

- Les paquets excédentaires sont mis en file d'attente.
- Le trafic est retardé, pas abandonné.
- Déployé vers les fournisseurs de services.

Traffic Policing

- Le trafic excédentaire est abandonné ou re-marqué.
- Appliqué à la périphérie du réseau.

Chapitre 7 – Les antennes

1. Les ondes radio (Radio Waves)

Définition

- Les ondes radio font partie des ondes électromagnétiques.
- Générées par des oscillations d'un courant alternatif.
- Composées de deux champs perpendiculaires :
 - champ électrique
 - champ magnétique
- Ces champs sont en phase et se propagent dans l'espace.

Paramètres clés

- Période (T) : temps nécessaire pour un cycle complet.
- Fréquence (f) : nombre de cycles par seconde (Hz).
- Longueur d'onde (λ) :
 - distance entre deux crêtes
 - $\lambda = v / f$
- Phase (ϕ) : position dans le cycle.
- Vitesse de propagation (v) :
 - quasi constante dans l'air
 - influencée par le milieu traversé.

2. Types d'ondes et propagation

Onde de sol (ou de surface)

- Se propage le long du sol.
- Indépendante des conditions atmosphériques.
- Fréquences basses (kHz à 1 MHz).
- Limites :
 - portée courte
 - sensible aux obstacles terrestres.

Onde d'espace

- Fréquences > 30 MHz.
- Résultat :
 - onde directe (ligne de vue)
 - ondes réfléchies.
- Sensible aux obstacles :
 - dimensions > λ provoquent des blocages.

Onde de ciel

- Réfléchi par l'ionosphère.
- Dépend :
 - du cycle jour/nuit
 - des saisons.
- Peut être absorbée, réfractée ou réfléchi.
- Utile pour communications longue distance.
- Phénomène imprévisible.

3. Rapport Signal/Bruit (SNR) et incidents de propagation

SNR (Signal to Noise Ratio)

- Mesure la qualité du signal utile par rapport au bruit.
- Plus le SNR est élevé, meilleure est la performance.
- Exemple : SNR > 25 dB pour Wi-Fi haut débit.

Sources de bruit

- | | |
|------------------------|---------------------------|
| • Autres réseaux Wi-Fi | • Micro-ondes |
| • Bluetooth | • Équipements industriels |

Incidents de propagation

- Atténuation en espace libre (FSPL) :
 - perte proportionnelle à la distance
 - $FSPL = 32,4 + 20 \log f + 20 \log d$
- Réflexion :
 - rebond sur surfaces (verre, plastique)
- Absorption :
 - perte d'énergie dans les matériaux
 - métal et béton absorbent fortement
- Réfraction :
 - changement d'angle lors du passage dans un milieu
- Diffraction :
 - contournement d'obstacles
- Diffusion :
 - dispersion sur surfaces rugueuses
- Chemins multiples (multipath) :
 - interférences entre ondes directes et réfléchies
- Fading :
 - évanouissement du signal
 - protections : antennes directives, diversity, contrôle de gain automatique.

4. Zone de Fresnel

- Ellipsoïde autour de la ligne de vue RF.
- Obstacles :
 - < 40 % : impact limité
 - < 20 % : recommandé avec marge.
- La ligne de vue optique $\neq$ ligne de vue RF.
- Les arbres et la végétation réduisent la marge.

5. Pertes de transmission et mesures

Pertes de transmission

- FSPL :
 - augmente avec la fréquence et la distance.
- Variable rate shifting :
 - débit élevé = portée réduite.
- Fréquence :
 - plus élevée = atténuation plus rapide.

RSSI

- Puissance du signal reçu.
- Exprimée en dBm.
- Valeurs Wi-Fi :
 - -30 dBm : excellent
 - -90 dBm : faible.
- Utilisations :
 - sélection d'antenne
 - handovers
 - géolocalisation
 - CSMA/CA.

Sensibilité du récepteur

- Seuil minimal pour détecter le signal.
- Exemple Wi-Fi : -85 dBm.
- Condition : signal reçu > sensibilité.

6. Caractéristiques des antennes

- Rôle :
 - conversion énergie électrique $\leftrightarrow$ ondes électromagnétiques.
- Résistance de rayonnement :
 - adaptation d'impédance (ex. : 75 Ω).
- Bande passante :
 - plages de fréquences supportées.
- Polarisation :
 - horizontale, verticale ou circulaire.
- Gain :
 - concentration du rayonnement.
 - dBi (isotropique)

- dBd (dipôle).
- Diagramme de rayonnement :
 - H-plane : azimut
 - E-plane : élévation.
- EIRP (PIRE) :
 - $EIRP = P_{out} - \text{pertes câble} + \text{gain antenne}$.
 - Réglementation :
 - ETSI : 20 dBm
 - FCC : 36 dBm.
- Background noise :
 - bruit ambiant (ex. micro-ondes à 2,4 GHz).

7. Types d'antennes

- Isotropique :
 - théorique
 - gain 0 dBi.
- Dipôle :
 - omnidirectionnelle
 - gain $\sim 2,14$ dBi.
- Patch (Flat Panel) :
 - semidirectionnelle
 - gain 8 à 20 dBi.
- Yagi :
 - directionnelle
 - gain 10 à 15 dBi.
- Parabolique (Dish/Grid) :
 - hautement directionnelle
 - gain 20 à 30 dBi.

8. Accessoires d'antennes

- Amplificateurs :
 - augmentent le signal
 - alimentation requise.
- Splitters :
 - répartissent le signal
 - pertes ~ 4 dB
 - débit divisé.

9. Calculs et transmission radio

- Atténuation :
 - -3 dB = puissance divisée par 2.
- Puissance (dBm) :
 - $1 \text{ W} = 30 \text{ dBm}$.
- FSPL :
 - $32,4 + 20 \log f + 20 \log d$.
- EIRP :
 - $P_{out} - C_t + G_t$.

- Puissance reçue (Pr) :
 - Pr > sensibilité du récepteur.
- Toujours prévoir une marge pour les obstacles.

10. Exemple pratique – Distance maximale

- Calcul basé sur :
 - puissance d'émission
 - pertes de câbles
 - gain des antennes
 - sensibilité du récepteur.
- Résultat :
 - distance théorique $\approx 1,1$ km
 - marge recommandée en conditions réelles.

Chapitre 6

Pentesting Phase 1 : Pre-engagement Interactions

1. Interactions de pré-engagement

Définition des accords contractuels et financiers

- Établir un cadre légal, technique et organisationnel validé par les deux parties.
- Inclure des clauses de confidentialité.
- Le pentest ne peut commencer sans accord formel.

Règles d'engagement claires

- Compréhension mutuelle de ce qui se passera pendant le test.
- Définition précise :
 - des systèmes, données, processus et activités inclus.
 - du type de pentest (white / grey / black box).
 - des informations disponibles pour le pentester.
- Mise en place de canaux de communication sécurisés.
- Définition du budget.

Autorisation du client

- Le client doit fournir une autorisation formelle via un contrat.
- Toute action hors contrat est illégale et assimilée à du piratage.

2. Déterminer la raison du pentest

Pentest basé sur un objectif précis (Goal-based)

- Tester une nouvelle application avant la mise en production.
- Évaluer la sécurité d'une organisation récemment acquise.

Pentest de conformité (Compliance-based)

- Vérifier la conformité à une loi ou une norme.
- Peut exiger un prestataire certifié.
- Souvent imposé par des réglementations.

Pentest en mode Red Team

- Simuler des attaques réalistes et crédibles.
- Tester la réaction des équipes internes (Blue Team).
- Plus ciblé, ne cherche pas à lister toutes les failles.

3. Définir le périmètre (Scope)

Éléments à tester

- Quels systèmes, réseaux ou services sont inclus ?
- Quand les tests ont lieu et leur durée.
- Quelles techniques sont autorisées ou interdites.
- Quelles autorisations le pentester doit posséder.
- Procédure à suivre en cas de problème ou incident.
- Existence éventuelle de zones interdites.

Plan d'action

- Le prestataire doit comprendre l'ensemble du périmètre.
- Permet d'établir un plan d'action clair et structuré.

4. Aspects légaux et confidentialité

Législation

- Respect des lois locales.
- Documentation claire de l'autorisation du client.
- Connaissance des lois applicables au lieu du pentest.
- Certains outils peuvent être considérés comme des armes.

Confidentialité

- Signature d'un accord de non-divulgence (NDA).
- Définition du traitement des données sensibles :
 - vulnérabilités
 - mots de passe
- Suppression de tous les enregistrements après la mission.

Autres concepts juridiques

- SLA (Service Level Agreement) :
 - attentes en termes de qualité, délais et coûts.
- Statement of Work (SOW) :
 - activités à réaliser.
- Contrat :
 - termes de l'accord et paiement.
- Clauses de non-responsabilité :
 - limitation de responsabilité en cas de perte de données.
- Réglementations (exemples)
 - RGPD : protection des données (Europe).
 - GLBA : secteur financier (USA).
 - HIPAA : santé (USA).
 - PCI-DSS : cartes de paiement.

5. Types de pentest selon les connaissances du prestataire

Black Box (Unknown-environment testing)

- Aucune ou très peu d'informations sur la cible.
- Simule un attaquant externe.
- Avantages :
 - réaliste
 - rapide
 - teste les réactions défensives.
- Inconvénients :
 - moins exhaustif
 - peu de visibilité sur la configuration interne.

White Box (Known-environment testing)

- Accès complet aux informations :
 - schémas
 - identifiants
 - configurations
 - code source.
- Analyse approfondie.
- Simule un administrateur interne.
- Nécessite un haut niveau de compétences.

Grey Box (Partially known environment testing)

- Informations limitées.
- Approche hybride.
- Simule un poste client compromis.
- Montre ce qu'un utilisateur normal peut atteindre.

Chapitre 6 – Pentesting Phase 2 : Intelligence Gathering

1. Objectifs de la Collecte d'Informations

- Rassemblement d'informations sur l'entreprise : sites, agences, employés (rôles), FAI, adresses IP des serveurs publics, logiciels utilisés, adresses e-mail.
- Identification des systèmes cibles : découvrir les différents systèmes de l'entreprise et leurs spécificités.
- Priorisation des cibles : établir une liste de cibles classées par ordre de priorité pour les phases ultérieures du pentest.

2. Méthodes de Collecte d'Informations

- Reconnaissance Passive : outils n'interagissent pas directement avec la cible, collecte de données accessibles publiquement (réseaux sociaux, WHOIS, DNS), idéal pour ne pas être détecté, plus difficile d'obtenir des informations utiles.
- Reconnaissance Semi-Passive : interaction avec la cible via trafic et comportement normaux, navigation sur application ou site web, moins intrusive que la reconnaissance active mais plus interactive que la passive.

- Reconnaissance Active : interaction directe avec la cible, utilisation de scanners de ports ou vulnérabilités pour découvrir hôtes, ports ouverts, services, versions et systèmes d'exploitation, interactions détectables par les systèmes de défense.

3. Reconnaissance Passive ou Semi-Passive: OSINT (Open-Source INTelligence)

- Sources d'informations : sites web, conférences, médias sociaux, registres DNS, déclarations fiscales.
- Utilité : rendre plus crédibles les attaques d'ingénierie sociale.
- Informations recherchées : mesures de sécurité physique, relations de l'entreprise, dates importantes, offres d'emplois, listes d'employés, médias sociaux, métadonnées des documents, informations sur les réseaux, contre-mesures existantes.
- Outils : DNSdumpster, Dnsrecon, FOCA, Exiftool, meta-extractor, host, dig, nslookup, tracer, WHOIS Lookups, Spiderfoot, Recon-ng.
- Moteurs spécialisés : Shodan (objets connectés à Internet), Censys (appareils connectés, services exposés, informations géographiques).

4. Reconnaissance Active

- Scanners de ports : découverte des hôtes et ports ouverts.
- Identification des services : type, version et vulnérabilités des services.
- Détection du système d'exploitation (OS fingerprinting).
- Détection des vulnérabilités connues : scripts Nmap Scripting Engine (NSE), base de données CVE.
- Informations supplémentaires (whitebox) : SCCM, Jamf Pro, GLPI, fichiers journaux, fichiers de configuration, code source.
- Outils : Nmap, Zenmap, Masscan, Nessus, OpenVAS, Qualys, Nikto, Burp Suite.

5. Network Scanning avec Nmap

- Découverte des périphériques actifs et collecte d'informations.
- Cartographie du réseau : hôtes actifs.
- Ports/services actifs : TCP/UDP actifs.
- Détection de service : type et version.
- Détection du système d'exploitation.
- Détection des vulnérabilités connues (CVE).

Types de scans

- Connect Scan (-sT) : connexion TCP complète, plus bruyant.
- Scans furtifs (Stealth Scans) : SYN Scan (-sS), FIN Scan (-sF), Null Scan (-sN), Xmas Scan (-sX).

Découverte des hôtes

- ICMP ECHO Request (-PE), ICMP Timestamp (-PP), ICMP Address Mask Request (-PM)
- TCP SYN Scan (-PS), TCP ACK ping (-sA), UDP scan (-sU), IP protocol ping (-PO), ARP Scan (-PR), Discovery scan (-sn)

États des ports

- Open, Closed, Filtered, Unfiltered, Open|filtered, Closed|filtered

Détection avancée

- Détection d'OS (-O)
- Détection des services (-sV)
- Nmap Scripting Engine (NSE) : version, malware, backdoor, vulnerability, discovery
- Énumération des utilisateurs et groupes : scripts SMB (smb-enum-users, smb-enum-groups, smb-enum-shares)

Réglementation et gestion

- Scan non-approuvé → conséquences légales/professionnelles, autorisation expresse requise
- Gestion Nmap : politiques, procédures, sauvegarde, chiffrement, durée de conservation, classification

Pentesting Phase 3 : Threat modeling

1. Objectifs de la Modélisation des Menaces

- Comprendre les menaces et vulnérabilités : identifier quelles menaces et attaques pourraient exploiter quelles vulnérabilités.
- Identifier les cibles d'intérêt : déterminer quels actifs de l'entreprise sont les plus susceptibles d'intéresser les hackers.
- Caractériser les attaquants : comprendre les types de hackers et leurs motivations.
- Évaluer l'impact des menaces : identifier les menaces avec impact significatif sur l'organisation.
- Détecter les points faibles : faiblesses spécifiques des applications, systèmes, infrastructure (ex. angles morts des caméras).
- Faciliter la mise en œuvre de contre-mesures : déploiement d'outils, systèmes, contrôles et processus adaptés.

2. Exemple Simple de Modélisation des Menaces

- Actif : Base de données SQL
- Menace potentielle : Attaque par injection SQL
- Contre-mesure : Déploiement d'un Web Application Firewall (WAF)

3. Étapes d'un Processus de Modélisation des Menaces

1. Définition de la Portée : applications, données, services, partenaires, processus ; comprendre systèmes et flux de données.
2. Identification des Menaces : scénarios d'attaque probables, documentation, catégories STRIDE (Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege).
3. Évaluation des Risques : impact et probabilité, niveau de risque (faible, moyen, élevé), définir objectifs et exigences de sécurité.
4. Prévention/Mitigation : mettre en œuvre contrôles et protections pour contrer les menaces.
5. Validation/Remédiation : tester et valider l'efficacité des contrôles, réviser et améliorer le processus.

4. Modélisation des Menaces et Pentesting (selon PTES - Penetration Testing Execution Standard)

- Actifs : identifier les plus susceptibles d'être ciblés, déterminer valeur et impact potentiel ; informations via documentation interne et personnel clé.
 - Exemples : secrets commerciaux, données de R&D, brevets, propriété intellectuelle, informations financières, codes sources, données PII/PHI, personnel, infrastructure, chaîne de production.
- Attaquant : identifier acteurs de la menace (cybercriminels, hacktivistes, internes, externes), analyser capacités (exploits, botnets, moyens), évaluer accessibilité aux actifs.

5. Avantages de la Modélisation des Menaces pour le Pentesting

- Ciblage précis : déterminer les cibles réelles pour tester contrôles, processus et infrastructures pertinents.
- Imitation réaliste des attaques : pentest imite outils, techniques, capacités et accessibilité des attaquants réels.

6. MITRE ATT&CK® (Adversarial Tactics, Techniques, and Common Knowledge)

- Tactique : ce que l'attaquant essaie de faire (ex. reconnaissance).
- Technique : comment l'attaquant y parvient (ex. scan de ports).
- Procédure : mise en œuvre spécifique de la technique.

7. Utilité de MITRE ATT&CK®

- Simulation d'attaques : aide à simuler cyberattaques pour tester cyberdéfenses.
- Configuration de la sécurité : facilite choix et configuration des technologies de sécurité pour détecter, éviter et atténuer les cybermenaces.
- Langage commun : standardisé pour partager informations sur cybermenaces et collaborer à leur prévention.

Pentesting Phase 4 : Vulnerability analysis

1. Objectifs de l'Analyse des Vulnérabilités

- Identifier les vulnérabilités exploitables : découvrir les failles de sécurité utilisables par un attaquant.
- Corréler les informations : mettre en relation OS, applications et bases de vulnérabilités connues.
- Analyser en profondeur : examiner code source, configurations, métadonnées pour déceler des faiblesses.
- Éviter les doublons : chaque vulnérabilité comptabilisée une seule fois.
- Vérifier l'exactitude : confirmer que les vulnérabilités détectées sont réelles et exploitables.
- Lister les attaques possibles : établir liste des attaques pour la phase d'exploitation.

2. Méthodes et Techniques d'Identification des Vulnérabilités

1. Corrélation avec les Vulnérabilités Connues (CVE) : comparer versions OS/applications avec bases publiques CVE.
2. Analyse du Code Source (White Box) : identifier erreurs de programmation, failles logiques, mauvaises pratiques.

3. Analyse des Métadonnées : documents, images, informations sensibles, logiciels utilisés et versions.
4. Analyse des Fichiers de Configuration : configurations faibles, mots de passe par défaut, paramètres mal définis.
5. Ingénierie Inverse (Reverse Engineering) : désassembler ou décompiler logiciels pour identifier vulnérabilités cachées.
6. Utilisation de Scanners de Vulnérabilités : Nessus, OpenVAS, Qualys. Peut faire partie de la collecte active PTES.

3. Vérification de l'Exactitude des Vulnérabilités

1. Recherche d'Informations : lire documentation CVE, comprendre conditions d'exploitation et scénarios d'attaque.
2. Cross-Validation : comparer résultats avec différents scanners/outils.
3. Test Manuel : reproduire vulnérabilité sur le système affecté (ex. injection SQL).

4. Création de la Liste des Attaques Possibles

- | | |
|----------------------------|---|
| • Phishing | • Attaques par déni de service (DoS) |
| • Tailgating (talonnage) | • Clonage de badges |
| • Attaques par force brute | • Exploitation de configurations par défaut |
| • Keylogger | • Exploitation de logiciels obsolète |
| • Buffer overflow | |
| • Evil twin | |
| • Injection SQL | |

5. Le Scanner de Vulnérabilité Nessus (Exemple Détaillé)

Modèles de Scan :

- Discovery : découverte d'hôtes
- Vulnerabilities : analyse des vulnérabilités
- Compliance : vérification conformité
- Note : certains modèles indisponibles dans version Essentials

Programmation des Scans : planifier pendant faible activité réseau

Notification des Scans : configuration SMTP, filtres possibles

Paramètres de Découverte (Discovery) :

- Host Discovery : découvrir hôtes actifs, ports TCP intégrés, option "Avoid potential false alarms"

Port Scanning : Full TCP 3-way handshake, TCP SYN scan

Paramètres d'Évaluation (Assessment) :

- Report Paranoia : show potential false alarms / avoid potential false alarms
- Profondeur des tests : thorough tests
- Hydra : options si installé
- Web Application Tests : browser emulation, start page, max depth

Plugins : détecter vulnérabilités spécifiques, activer/désactiver

Rapports : hôte, vulnérabilité, gravité, recommandations, filtres, exclusion d'hôtes morts

6. Politiques Nessus (Nessus Policies)

- Policy : ensemble d'options de configuration prédéfinies
- Création à partir de modèles existants, personnalisation possible
- Plug-ins Rules : redéfinir niveaux de gravité pour correspondre au profil de sécurité

Pentesting Phase 5 : Exploitation

1. Objectifs Principaux

- Démontrer l'exploitabilité des vulnérabilités : prouver que les failles de sécurité découvertes sont réellement exploitables et permettent de contourner les restrictions de sécurité.
- Établir un accès : obtenir un accès non autorisé à un système, une application ou une ressource.
- Choisir et mettre en œuvre les attaques :
 - Priorisation des vulnérabilités : vulnérabilités faciles à exploiter testées en premier.
 - Impact élevé : vulnérabilités avec fort impact sur l'entreprise (données sensibles, systèmes critiques).
- Respecter les règles de pré-engagement : actions conformes aux objectifs définis et aux risques acceptés, en tenant compte des perturbations potentielles.
- Rester discret : choix d'attaques discrètes pour éviter d'alerter les équipes de défense.

2. Exemples de Pistes d'Attaques

- Injection SQL : commandes SQL malveillantes pour contourner l'authentification ou extraire des informations de bases de données.
- Craquage d'identifiants :
 - Brute force : essai systématique de toutes les combinaisons possibles.
 - Attaque par dictionnaire : listes de mots de passe couramment utilisés (Hydra pour SSH).
- Attaques physiques :
 - Lockpicking : ouverture de serrures physiques pour accéder à des zones restreintes.
- Buffer Overflow : exploitation de programmes ne vérifiant pas la taille des entrées utilisateur pour injecter du code malveillant et obtenir un shell ou des privilèges élevés.
- Ingénierie sociale :
 - Talonnage (Tailgating) : suivre une personne autorisée pour entrer dans une zone restreinte.
 - Phishing ciblé : e-mails frauduleux personnalisés pour divulguer des informations ou exécuter des logiciels malveillants.
- Attaque Evil Twin : faux point d'accès Wi-Fi pour intercepter les données des utilisateurs.
- Clé USB malveillante (Rubber Ducky) : clés USB infectées laissées dans des lieux stratégiques.
- Directory Traversal / Climbing : manipulation de chemins de fichiers pour accéder à des répertoires non autorisés.
- Vol de session (XSS Stored) : injection de scripts malveillants pour voler les cookies de session et usurper l'identité.

Pentesting Phase 6 : Post-exploitation

1. Objectifs Principaux

- Consolider l'accès : maintenir un accès permanent au système compromis sans répéter l'attaque initiale.
- Élever les privilèges : obtenir des droits supérieurs (root, administrateur).
- Explorer : comprendre l'environnement et identifier d'autres systèmes accessibles.
- Exfiltrer des données : démontrer la capacité à accéder et extraire des informations sensibles.
- Compromettre d'autres systèmes (Mouvement Latéral / Pivoting) : utiliser le système compromis comme point de départ.
- Effacer les traces : supprimer les preuves de l'intrusion pour éviter la détection.

2. Outils de Post-Exploitation

- Persistance et Commandes à Distance : Meterpreter, PsExec, Sliver.
- Collecte de Données : Mimikatz, LaZagne, PowerSploit.
- Mouvement Latéral et Escalade de Privilèges : CrackMapExec, BloodHound, SharpHound, PowerView.
- Command and Control (C2) : Covenant, Cobalt Strike, Empire.
- Utilitaires Légitimes : PowerShell, Sysinternals, WMI, Python, Bash, SMB, NFS, RDP, VNC (éveillent moins de soupçons).

3. Techniques de Post-Exploitation

3.1 Consolider l'Accès

- Installation de backdoors : bind shells, reverse shells (Netcat).
- Création de comptes utilisateurs cachés.
- Manipulation de tâches planifiées.
- Désactivation des systèmes de protection.
- Modification des scripts de démarrage.

3.2 Élévation de Privilèges (Privilege Escalation)

- Escalade verticale et escalade horizontale.
- SMB Relay Attack (Responder).
- Buffer Overflow.
- Jailbreaking / Rooting.
- Permissions mal configurées.
- Vulnérabilités spécifiques (CVE-2019-0841).

3.3 Explorer

- Exploration du système : ipconfig, netstat, net user, tasklist, systeminfo, reg query, find.
- Exploration de l'environnement : PowerView, BloodHound.

3.4 Pivoting (Mouvement Latéral)

- Utiliser une machine compromise pour attaquer d'autres systèmes.
- Outils : Metasploit, Proxychains, Chisel.
- Protocoles légitimes : RDP, VNC, SSH.
- Pass-the-Hash / Pass-the-Ticket (Mimikatz).

3.5 Exfiltration des Données

- Déplacer des données sensibles hors de l'organisation.
- Tunnels chiffrés : VPN, SSH.
- Canaux cachés :
 - Tunnel DNS (DNScat2, Iodine).
 - Tunnel ICMP (Ptunnel, ICMPtunnel).
- Stéganographie.

3.6 Effacer les Traces

- Désactiver ou supprimer les journaux d'événements.
- Supprimer comptes utilisateurs, fichiers, commandes.
- Manipuler métadonnées et horodatages (Timestomp).
- Restaurer les systèmes à leur état d'origine.

4. Attaquer les Mots de Passe

- Brute-force.
- Attaque par dictionnaire (wordlist).
- Attaque combinée.
- Attaque par masque.
- Attaque hybride.
- Outils : John the Ripper, Hashcat, Cain and Abel, Mimikatz, RainbowCrack.
- Tables arc-en-ciel : hachages précalculés, moins efficaces pour mots de passe longs, complexes et salés.

5. Metasploit Framework

- Outil complet : toutes les phases du pentesting.
- Composants principaux :
 - Msfconsole
 - Modules
 - Outils (msfvenom, pattern_create)
- Catégories de modules : Auxiliary, Encoders, Exploits, Post.
- Payloads :
 - Singles
 - Stagers
 - Stages (Meterpreter)
 - Adapters
- Commandes clés : show payloads, search, use, check, set, unset, exploit, run, sessions.

